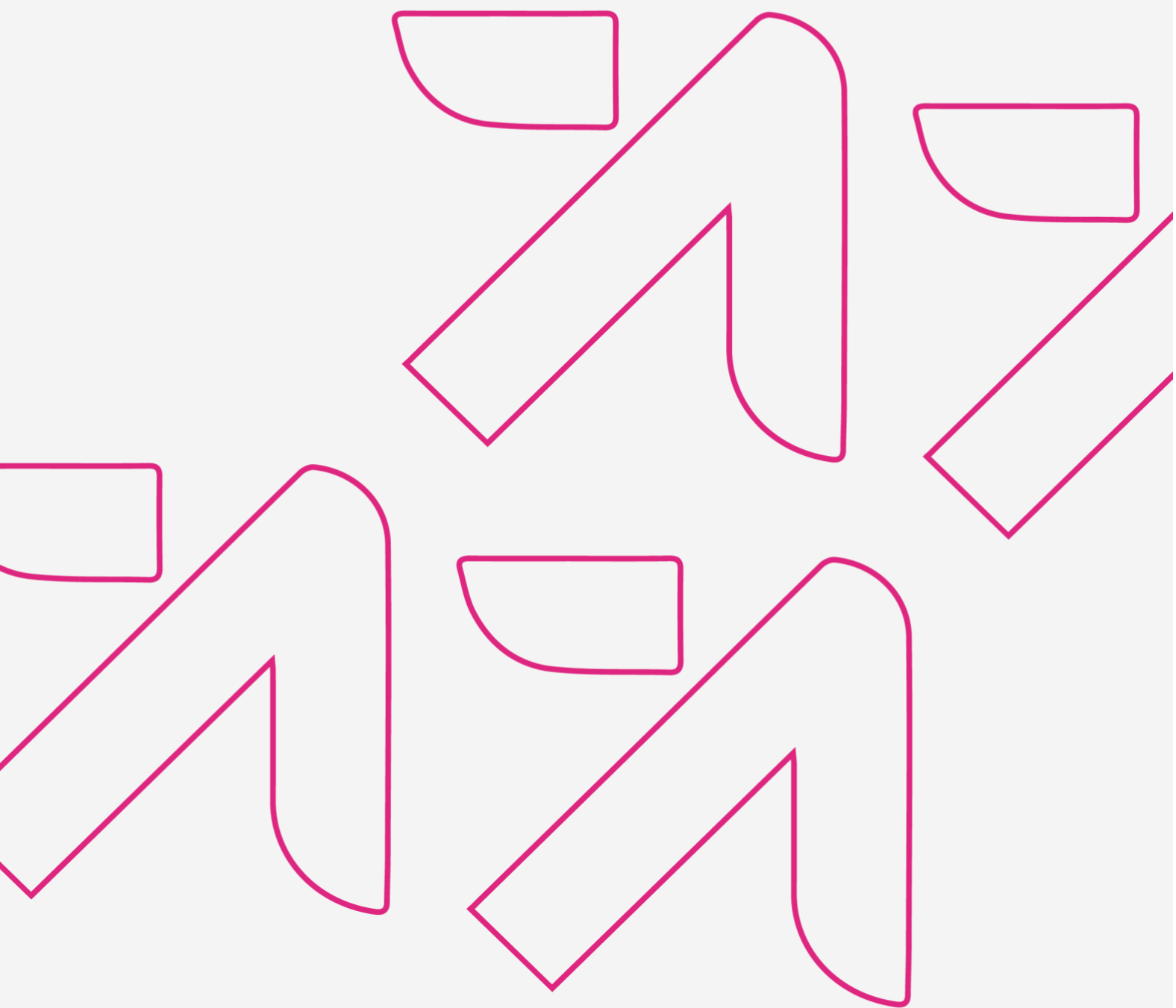




Máster de

Ciberseguridad Hacking Ético

[Módulo Incidentes de Ciberseguridad]

Curso académico 2026/2027 - Edición Presencial

Tema 5 – Actividad 1. Plan de auditoría

Encaje en el curso 2026/2027: RA3 · tema 5 del temario oficial. Actividades propias para trabajar en clase; no sustituyen a las obligatorias del campus.

1. Enunciado

Prepara el plan de una auditoría interna de seguridad para una clínica dental con dos sedes, doce empleados, un programa de gestión de pacientes en la nube y un servidor local de radiografías. El objetivo es practicar la fase que más se descuida: decidir qué se revisa y con qué criterio antes de empezar.

2. Guía paso a paso

1. Define el objetivo y el alcance: qué entra y qué queda fuera.
2. Elige los criterios: norma, política o buenas prácticas con las que vas a comparar.
3. Haz el inventario de activos principales y señala los tres de mayor riesgo.
4. Decide qué técnicas usarás en cada área: revisión documental, entrevista, prueba técnica.
5. Indica qué autorizaciones necesitas y de quién.
6. Entrega el plan en una página, con calendario.

Reto extra (opcional): esta clínica trata datos de salud: añade al plan qué revisarías en concreto por exigencia del RGPD.

Tema 5 – Actividad 2. Auditar la capacidad de respuesta

1. Enunciado

Aplica la lista de comprobación de capacidad de respuesta a incidentes de los apuntes a una organización que conozcas (tu trabajo, tu centro o un caso que te dé la profesora). El objetivo es convertir una lista de preguntas en hallazgos con evidencia.

2. Guía paso a paso

1. Convierte cada pregunta de la tabla en una comprobación concreta: qué pedirías ver.
2. Recoge la respuesta y la evidencia de cada una; si no la hay, anótalo.
3. Valora cada punto: conforme, no conformidad menor, no conformidad mayor u observación.
4. Elige los tres hallazgos más graves.

5. Redacta cada uno con criterio, condición, evidencia y recomendación.
6. Entrega la lista completa y los tres hallazgos redactados.

Reto extra (opcional): añade a la lista cinco comprobaciones técnicas que puedas verificar en Wazuh, por ejemplo qué equipos no tienen agente.

Tema 5 – Actividad 3. Informe de hallazgos

1. Enunciado

A partir de estas notas de campo, redacta el apartado de hallazgos de un informe de auditoría. Notas: las copias de seguridad se hacen cada noche en un disco USB conectado al servidor; nadie recuerda la última restauración de prueba; hay cuatro cuentas de exempleados activas; el plan de respuesta a incidentes es de 2021 y cita a un responsable que ya no trabaja allí; todos los equipos tienen antivirus actualizado; el acceso remoto usa VPN con contraseña, sin segundo factor.

2. Guía paso a paso

1. Separa lo que es un hallazgo de lo que es una conformidad.
2. Asigna a cada hallazgo una severidad y justifícala por el riesgo.
3. Redacta cada hallazgo con sus cuatro elementos.
4. Propón para cada uno una acción, un responsable y un plazo razonable.
5. Escribe un resumen ejecutivo de cinco líneas para la dirección.
6. Entrega el informe en una o dos páginas.

Reto extra (opcional): imagina que esta empresa sufre un ransomware la semana siguiente: explica cómo habría influido cada hallazgo en el desarrollo del incidente.